12 Security: Authorization and auditing

This chapter covers

- Authorization and roles with Spring Cloud Gateway and OAuth2
- Protecting APIs with Spring Security and OAuth2 (imperative)
- Protecting APIs with Spring Security and OAuth2 (reactive)
- Protecting and auditing data with Spring Security and Spring Data

In the previous chapter, I introduced access control systems for cloud native applications. You saw how to add authentication to Edge Service with Spring Security and OpenID Connect, manage the user session life cycle, and address CORS and CSRF concerns when integrating an Angular frontend with Spring Boot.

By delegating the authentication step to Keycloak, Edge Service is not affected by the specific authentication strategy. For example, we used the login form feature offered by Keycloak, but we could also enable social login via GitHub or rely on an existing Active Directory to authenticate users. Edge Service only needs to support OIDC to verify that the authentication happened correctly and get information about the user via an ID Token.

There are still a few issues we haven’t addressed. Polar Bookshop is a distributed system, and after a user authenticates successfully with Keycloak, Edge Service is supposed to interact with Catalog Service and Order Service on behalf of the user. How can we securely propagate the